

## MAPEO DETALLADO: PREGUNTAS → REQUISITOS NORMATIVOS

### Trazabilidad de Encuesta Mercury a NIS2, ISO 27001, NIST CSF v2.0

#### INTRODUCCIÓN

Este documento vincula cada pregunta de la encuesta Mercury a requisitos específicos de:

- **NIS2** (Directiva UE 2022/2555)
- **ISO/IEC 27001:2022** (Standard Internacional)
- **NIST Cybersecurity Framework v2.0** (Framework EEUU)

Esto proporciona evidencia de conformidad para auditorías regulatorias.

#### DOMINIO 1: GOBERNANZA Y RIESGOS (GR)

| #     | Pregunta Encuesta                                  | NIS2 Requisito                              | ISO 27001 Clause              | NIST CSF 2.0            | Evidencia Solicitar                     |
|-------|----------------------------------------------------|---------------------------------------------|-------------------------------|-------------------------|-----------------------------------------|
| GR-P1 | ¿Existe metodología formal de análisis de riesgos? | Art. 20 Medidas técnicas/organizacionales   | 6.1.1 Planes de tratamiento   | Govern Function         | Documento ISO 27005 o NIST SP 800-30    |
| GR-P2 | ¿Se cuantifican riesgos en moneda (AVRQ/FAIR) ?    | Art. 20 (implícito: análisis cuantitativos) | 8.3 Determinación controles   | Govern Function         | Matriz AVRQ con valores monetarios      |
| GR-P3 | ¿Hay CISO designado formalmente?                   | Art. 15 Designación de responsable          | 5.3 Roles y responsabilidades | Govern Function (roles) | Contrato/ documento designación CISO    |
| GR-P4 | ¿Políticas de seguridad documentadas ?             | Art. 20 Medidas organizacionales            | 5.1 Políticas                 | Govern Function         | Políticas versión actual + distribución |
| GR-P5 | ¿Comunicación de políticas a todos empleados?      | Art. 20 (implícito: awareness)              | 7.3 Conciencia                | Govern Function         | Registro de distribución/training       |
| GR-P6 | ¿Plan de tratamiento para riesgos críticos?        | Art. 20 Tratamiento de riesgos              | 6.1.1 Planes                  | Govern Function         | Matriz riesgos con planes asignados     |

## DOMINIO 2: VULNERABILIDADES Y PARCHES (VUL)

| #      | Pregunta Encuesta                        | NIS2 Requisito                   | ISO 27001 Clause          | NIST CSF 2.0       | Evidencia Solicitar                        |
|--------|------------------------------------------|----------------------------------|---------------------------|--------------------|--------------------------------------------|
| VUL-P1 | ¿Se realiza escaneo de vulnerabilidades? | Art. 21 Testing periodicos       | 8.7 Remediación           | Identify / Protect | Reportes LAST 90 DÍAS escaneo              |
| VUL-P2 | ¿Frecuencia de escaneo (mínimo)?         | Art. 21 (implícito: regularidad) | 8.7 Periodicidad          | Protect Function   | Calendario escaneo documentado             |
| VUL-P3 | ¿Base de datos de vulnerabilidades?      | Art. 21 Inventario               | 8.6 Gestión configuración | Identify Function  | VDB/CMDB con datos vulnerabilidades        |
| VUL-P4 | ¿MTTR críticas <14 días (NIS2)?          | Art. 21 Plazo remediación        | 8.7 Plazos SLA            | Protect Function   | SLA documentado con evidencia cumplimiento |
| VUL-P5 | ¿Cobertura escaneo vs activos?           | Art. 21 Activos conocidos        | 8.1 CMDB                  | Identify Function  | % activos scaneados (meta: 95%+)           |
| VUL-P6 | ¿Pruebas penetración anual?              | Art. 21 Testing adicionales      | 8.7 Testing penetración   | Protect Function   | Reportes pentest ÚLTIMA año                |
| VUL-P7 | ¿Gestión de configuración basada?        | Art. 20 Seguridad configuración  | 8.6 Configuración es      | Protect Function   | Baselines de configuración documentados    |

### DOMINIO 3: SIEM E INCIDENTES (SIEM)

| #       | Pregunta Encuesta                    | NIS2 Requisito                           | ISO 27001 Clause            | NIST CSF 2.0     | Evidencia Solicitar                    |
|---------|--------------------------------------|------------------------------------------|-----------------------------|------------------|----------------------------------------|
| SIEM-P1 | ¿SIEM implementado?                  | Art. 20<br>Monitoreo de seguridad        | 8.15 Logging                | Detect Function  | SIEM screenshots / configuración       |
| SIEM-P2 | ¿Retención mínima 1 año?             | Art. 21<br>Registros auditables          | 8.15 Retención              | Detect Function  | Política retención documentada         |
| SIEM-P3 | ¿MTTD <4 horas críticas?             | Art. 21<br>(implícito: detección rápida) | 8.15 Alertas                | Detect Function  | Estadísticas MTTD últimos 90 días      |
| SIEM-P4 | ¿FPR <5%?                            | Art. 20<br>Efectividad controles         | 8.15 Tuning                 | Detect Function  | Reporte FPR con análisis               |
| SIEM-P5 | ¿Plan de respuesta a incidentes?     | Art. 19<br>Notificación incidentes       | 8.16 Respuesta a incidentes | Respond Function | Documento de plan + ejercicios         |
| SIEM-P6 | ¿MTTR incidentes críticos?           | Art. 21<br>Remediación                   | 8.16 Tiempo cierre          | Respond Function | SLA MTTR con cumplimiento              |
| SIEM-P7 | ¿Automatización de respuesta (SOAR)? | Art. 20<br>Eficiencia operacional        | 8.16 (implícito)            | Respond Function | % de incidentes automatizados          |
| SIEM-P8 | ¿Notificación CNCS <24h?             | Art. 21<br>Notificación incidente        | 6.5.2 Notificación          | Respond Function | Procedimiento notificación documentado |

## DOMINIO 4: CAPACITACIÓN DE EMPLEADOS (CAP)

| #             | Pregunta Encuesta                           | NIS2 Requisito                    | ISO 27001 Clause  | NIST CSF 2.0    | Evidencia Solicitar                  |
|---------------|---------------------------------------------|-----------------------------------|-------------------|-----------------|--------------------------------------|
| <b>CAP-P1</b> | ¿Programa de capacitación en seguridad?     | Art. 20 Conciencia de seguridad   | 7.3 Conciencia    | Govern Function | Curriculum + registro asistencia     |
| <b>CAP-P2</b> | ¿Cobertura de todos empleados?              | Art. 20 (todos son responsables)  | 7.3 Cobertura     | Govern Function | % de cobertura con lista             |
| <b>CAP-P3</b> | ¿Frecuencia mínima anual?                   | Art. 20 Actualización periódica   | 7.3 Periodicidad  | Govern Function | Calendario capacitación 2024-2025    |
| <b>CAP-P4</b> | ¿Evaluación de conocimiento?                | Art. 20 (implícito: verificación) | 7.3 Evaluación    | Govern Function | Resultados evaluaciones/ quizzes     |
| <b>CAP-P5</b> | ¿Phishing simulado regular?                 | Art. 20 Pruebas de consciencia    | 7.3 Pruebas       | Govern Function | Reportes de campañas últimos 6 meses |
| <b>CAP-P6</b> | ¿Tasa de click rate phishing?               | Art. 20 Métrica de mejora         | 7.3 KPIs          | Govern Function | Tendencias de click rate             |
| <b>CAP-P7</b> | ¿Tasa de reporte de phishing?               | Art. 20 Cultura de seguridad      | 7.3 Participación | Govern Function | # de emails reportados / total       |
| <b>CAP-P8</b> | ¿Capacitación especializada (CISO/admins )? | Art. 18 Roles especializados      | 7.3 Especializada | Govern Function | Certificaciones o cursos avanzados   |

## DOMINIO 5: CUMPLIMIENTO NORMATIVO (NORM)

| #              | Pregunta Encuesta                           | NIS2 Requisito                        | ISO 27001 Clause          | NIST CSF 2.0     | Evidencia Solicitar                     |
|----------------|---------------------------------------------|---------------------------------------|---------------------------|------------------|-----------------------------------------|
| <b>NORM-P1</b> | ¿Matriz de medidas NIS2 implementadas?      | Art. 20 Medidas técnicas (21 medidas) | 8.1-8.37 Controles        | Protect Function | Matriz 21 medidas con status            |
| <b>NORM-P2</b> | ¿% conformidad NIS2 actual?                 | Art. 20 (General: % implementación)   | 8.1-8.37 Cobertura        | Protect Function | % por medida + brecha                   |
| <b>NORM-P3</b> | ¿Auditoría interna de conformidad?          | Art. 20 Aseguramiento                 | 9.2 Auditorías internas   | Govern Function  | Reporte auditoría interna               |
| <b>NORM-P4</b> | ¿Plan remediación NIS2?                     | Art. 20 Timeline                      | 6.1.1 Planes de acción    | Govern Function  | Roadmap con hitos Q1-Q4 2026            |
| <b>NORM-P5</b> | ¿Cumplimiento GDPR verificado?              | GDPR Art. 32 (Seguridad datos)        | 8.1-8.37 Protección datos | Govern + Protect | Evaluación GDPR compliance              |
| <b>NORM-P6</b> | ¿ISO 27001 en alcance?                      | ISO 27001 Global                      | 6.1 Determinar alcance    | Govern Function  | Certificación o en auditoría            |
| <b>NORM-P7</b> | ¿Conformidad con NIST CSF?                  | NIST SP 800-53 (NIST CSF)             | 8.1-8.37 (alineación)     | Govern Function  | Mapeo NIST CSF actualizado              |
| <b>NORM-P8</b> | ¿Política de retención de registros >1 año? | Art. 21 Auditables                    | 8.15 Retención            | Detect + Respond | Política documentada con implementación |

## DOMINIO 6: GESTIÓN DE CADENA DE SUMINISTRO (SUPL)

| #              | Pregunta Encuesta                       | NIS2 Requisito                         | ISO 27001 Clause     | NIST CSF 2.0      | Evidencia Solicitar                   |
|----------------|-----------------------------------------|----------------------------------------|----------------------|-------------------|---------------------------------------|
| <b>SUPL-P1</b> | ¿Evaluación de riesgos de proveedores?  | Art. 20 Riesgos terceros               | 8.34 Terceros        | Identify Function | Matriz proveedores críticos + riesgos |
| <b>SUPL-P2</b> | ¿Cláusulas de seguridad en contratos?   | Art. 20 (implícito: responsabilidades) | 8.34 Requerimientos  | Protect Function  | Contrato template con cláusulas       |
| <b>SUPL-P3</b> | ¿Monitoreo de incidentes de terceros?   | Art. 21 Notificación proveedores       | 8.34 Monitoreo       | Detect Function   | Proceso de alerta de terceros         |
| <b>SUPL-P4</b> | ¿SBOM (inventario de software)?         | Art. 20 Supply chain seguridad         | 8.1 Activos software | Identify Function | SBOM documentado por sistema crítico  |
| <b>SUPL-P5</b> | ¿Auditoría de seguridad de proveedores? | Art. 20 Aseguramiento                  | 8.34 Auditorías      | Govern Function   | Reporte última auditoría proveedor    |

## DOMINIO 7: CONTROLES TÉCNICOS (CTRL)

| #              | Pregunta Encuesta                       | NIS2 Requisito                 | ISO 27001 Clause      | NIST CSF 2.0     | Evidencia Solicitar                |
|----------------|-----------------------------------------|--------------------------------|-----------------------|------------------|------------------------------------|
| <b>CTRL-P1</b> | ¿Cifrado en reposo de datos críticos?   | Art. 20 Protección datos       | 8.24 Criptografía     | Protect Function | Tecnología + configuración         |
| <b>CTRL-P2</b> | ¿Cifrado en tránsito (TLS 1.3+)?        | Art. 20 Integridad datos       | 8.24 Protocolos       | Protect Function | Configuración SSL/TLS actual       |
| <b>CTRL-P3</b> | ¿MFA en acceso remoto?                  | Art. 20 Autenticación fuerte   | 8.3 Control de acceso | Protect Function | % de usuarios con MFA activo       |
| <b>CTRL-P4</b> | ¿Gestión de identidades y acceso (IAM)? | Art. 20 Control de acceso      | 8.3 Identidades       | Protect Function | Plataforma IAM implementada        |
| <b>CTRL-P5</b> | ¿Segmentación de red?                   | Art. 20 Aislamiento            | 8.33 Segmentación     | Protect Function | Arquitectura segmentación actual   |
| <b>CTRL-P6</b> | ¿DLP (Prevención pérdida datos)?        | Art. 20 Protección información | 8.21 Protección datos | Protect Function | Tecnología + políticas DLP         |
| <b>CTRL-P7</b> | ¿Firewall perimetral?                   | Art. 20 Control perimetral     | 8.32 Firewall         | Protect Function | Configuración firewall documentada |
| <b>CTRL-P8</b> | ¿Antimalware actualizado?               | Art. 20 Protección malware     | 8.7 Malware           | Protect Function | % de sistemas protegidos           |

## DOMINIO 8: CONTINUIDAD (CONT)

| #       | Pregunta Encuesta                     | NIS2 Requisito                       | ISO 27001 Clause            | NIST CSF 2.0     | Evidencia Solicitar               |
|---------|---------------------------------------|--------------------------------------|-----------------------------|------------------|-----------------------------------|
| CONT-P1 | ¿Plan de continuidad de negocio?      | Art. 20 Continuidad                  | 8.37 Continuidad            | Govern Function  | Documento BCP actualizado         |
| CONT-P2 | ¿Plan de recuperación ante desastres? | Art. 20 Recuperación                 | 8.37 Recuperación           | Govern Function  | Documento DRP con RTO/RPO         |
| CONT-P3 | ¿Copias de seguridad automáticas?     | Art. 20 Disponibilidad               | 8.13 Backups                | Protect Function | Calendario + verificación backups |
| CONT-P4 | ¿Testing de recuperación anual?       | Art. 21 Pruebas                      | 8.37 Testing                | Govern Function  | Reporte últimos 12 meses testing  |
| CONT-P5 | ¿Sitio de recuperación activo?        | Art. 20 Redundancia                  | 8.37 Redundancia            | Protect Function | Descripción arquitectura DR       |
| CONT-P6 | ¿RTO documentado por sistema?         | Art. 20 Disponibilidad               | 8.37 Plazos                 | Govern Function  | Matriz RTO/RPO por criticidad     |
| CONT-P7 | ¿Seguros cibernéticos vigentes?       | Art. 20 (implícito: gestión riesgos) | 8.37 (Transferencia riesgo) | Respond Function | Póliza de seguro cibernético      |



## DOMINIO 9: GESTIÓN DE INCIDENTES Y RESPUESTA (RESP)

| #       | Pregunta Encuesta                     | NIS2 Requisito                             | ISO 27001 Clause    | NIST CSF 2.0     | Evidencia Solicitar                     |
|---------|---------------------------------------|--------------------------------------------|---------------------|------------------|-----------------------------------------|
| RESP-P1 | ¿Plan de respuesta a incidentes?      | Art. 19 Incidentes                         | 8.16 Plan respuesta | Respond Function | Documento de plan + equipo designado    |
| RESP-P2 | ¿Equipo de respuesta (IR Team)?       | Art. 19 (implícito: capacidad)             | 8.16 Equipo         | Respond Function | Organigrama + roles definidos           |
| RESP-P3 | ¿MTTR incidentes críticos?            | Art. 21 (implícito: velocidad)             | 8.16 SLA            | Respond Function | SLA MTTR con cumplimiento $\geq 95\%$   |
| RESP-P4 | ¿Comunicación de incidentes (CNCS)?   | Art. 21 Notificación <24h                  | 6.5.2 Notificación  | Respond Function | Procedimiento notificación documentado  |
| RESP-P5 | ¿Análisis forense post-incidente?     | Art. 21 (implícito: aprendizaje)           | 8.16 Análisis       | Respond Function | Reportes de análisis últimos 12 meses   |
| RESP-P6 | ¿Lecciones aprendidas documentadas?   | Art. 20 (Mejora continua)                  | 8.16 Mejora         | Respond Function | Matriz de incidentes + acciones         |
| RESP-P7 | ¿Ejercicios de simulación anualmente? | Art. 21 Testing                            | 8.16 Pruebas        | Respond Function | Reportes de simulacros últimos 12 meses |
| RESP-P8 | ¿Inteligencia de amenazas (TI)?       | Art. 21 (implícito: conocimiento amenazas) | 8.16 TI             | Detect Function  | Feeds de TI suscritos + utilizados      |

## DOMINIO 10: INTELIGENCIA DE AMENAZAS (INT)

| #      | Pregunta Encuesta                          | NIS2 Requisito                    | ISO 27001 Clause            | NIST CSF 2.0      | Evidencia Solicitar                   |
|--------|--------------------------------------------|-----------------------------------|-----------------------------|-------------------|---------------------------------------|
| INT-P1 | ¿Feeds de inteligencia de amenazas?        | Art. 21 (implícito: conocimiento) | 8.1 Información de amenazas | Identify Function | Lista feeds suscritos + consumo       |
| INT-P2 | ¿Participación en ISACs/grupos compartida? | Art. 21 Información compartida    | 8.1 Colaboración            | Identify Function | Membresía + participación documentada |
| INT-P3 | ¿Análisis de amenazas específicas sector?  | Art. 21 (Contexto sector)         | 8.1 Análisis                | Identify Function | Reportes de TI sector-específico      |
| INT-P4 | ¿Integración TI en SIEM?                   | Art. 21 (Efectividad detección)   | 8.15 Integración            | Detect Function   | Configuración integración SIEM-TI     |
| INT-P5 | ¿Actualización semanal de indicadores?     | Art. 21 (Actualidad)              | 8.1 Frecuencia              | Identify Function | Log de actualizaciones semanales      |

## DOMINIO 11: ACCESO REMOTO Y TELETRABAJO (REM)

| #      | Pregunta Encuesta                    | NIS2 Requisito             | ISO 27001 Clause           | NIST CSF 2.0     | Evidencia Solicitar                      |
|--------|--------------------------------------|----------------------------|----------------------------|------------------|------------------------------------------|
| REM-P1 | ¿VPN multi-factor + cifrado?         | Art. 20 Control remoto     | 8.3 Acceso remoto          | Protect Function | Configuración VPN + autenticación        |
| REM-P2 | ¿Políticas de seguridad teletrabajo? | Art. 20 Seguridad remota   | 8.3 Teletrabajo            | Govern Function  | Documento política de teletrabajo        |
| REM-P3 | ¿Monitoreo de acceso remoto?         | Art. 20 Auditoría acceso   | 8.15 Logging acceso remoto | Detect Function  | Registros acceso remoto (último 90 días) |
| REM-P4 | ¿Dispositivos personales (BYOD)?     | Art. 20 (Riesgo adicional) | 8.3 Dispositivos           | Protect Function | Política BYOD + MDM implementado         |

## DOMINIO 12: AUDITORÍA Y ASEGURAMIENTO (AUD)

| #      | Pregunta Encuesta                         | NIS2 Requisito                       | ISO 27001 Clause           | NIST CSF 2.0    | Evidencia Solicitar                |
|--------|-------------------------------------------|--------------------------------------|----------------------------|-----------------|------------------------------------|
| AUD-P1 | ¿Auditoría interna anual?                 | Art. 20 Aseguramiento                | 9.2 Auditorías internas    | Govern Function | Reporte auditoría última año       |
| AUD-P2 | ¿Auditoría externa (ISO 27001)?           | Art. 20 (Verificación independiente) | 9.3 Auditoría externa      | Govern Function | Certificado ISO 27001 o en proceso |
| AUD-P3 | ¿Evaluación de conformidad NIS2?          | Art. 20 Evaluación regulatoria       | 9.1 Evaluación conformidad | Govern Function | Reporte conformidad NIS2 (anual)   |
| AUD-P4 | ¿Trazabilidad de controles implementados? | Art. 21 Evidencia controles          | 9.1 Controles              | Govern Function | Matriz de controles con evidencia  |
| AUD-P5 | ¿Mejora continua documentada?             | Art. 20 Evolución                    | 10 Mejora continua         | Govern Function | Plan de mejora con seguimiento     |

## TABLA SUMARIA: REQUISITOS REGULATORIOS

| Regulación     | # Requisitos NIS2                 | # Cláusulas ISO 27001  | # Funciones NIST CSF 2.0                                         | % de Cobertura |
|----------------|-----------------------------------|------------------------|------------------------------------------------------------------|----------------|
| NIS2           | 21 medidas técnicas/org (Art. 20) | Alineadas en 8.1-8.37  | Todas 6 funciones                                                | 100%           |
| ISO 27001:2022 | 37 controles base                 | 37 cláusulas           | Alineadas en funciones                                           | 100%           |
| NIST CSF v2.0  | Mapeadas a medidas NIS2           | Alineadas en cláusulas | 6 funciones: Govern, Identify, Protect, Detect, Respond, Recover | 100%           |

## MATRIZ DE CONFORMIDAD: ENCUESTA → REGULACIONES

Para cada pregunta de encuesta:

Si Pregunta respuesta = Sí (Score  $\geq 3$ )  
→ Requisito NIS2 se considera CUMPLIDO  
→ Cláusula ISO 27001 se considera IMPLEMENTADA  
→ Función NIST CSF se considera CUBIERTA

Si Pregunta respuesta = NO (Score  $< 2$ )  
→ Requisito NIS2 BRECHA  
→ Cláusula ISO 27001 NO CUMPLIDA  
→ Función NIST CSF RIESGO

Cálculo de Conformidad Global:

% Conformidad = (# respuestas Score  $\geq 3$ ) / (Total preguntas)  $\times$  100%

## EJEMPLO: CÁLCULO DE CONFORMIDAD NIS2

**Si organización responde encuesta mercury:**

GR-P1 (Metodología riesgos) = Sí (Score 4) → Art. 20 CUMPLIDO ✓  
GR-P2 (Cuantificación AVRQ) = Parcial (Score 2) → Art. 20 BRECHA  
GR-P3 (CISO designado) = Sí (Score 5) → Art. 15 CUMPLIDO ✓  
...  
VUL-P4 (MTTR  $< 14$  días) = No (Score 1) → Art. 21 BRECHA  
...

Total Conformidad NIS2 = 18/21 medidas = 85.7% CONFORME

Status: PARCIALMENTE CONFORME ( $> 80\%$  recomendado)

Acción: Remediar 3 brechas antes Q1 2026

Timeline: 6-8 semanas para alcanzar 100%

## REFERENCIAS NORMATIVAS COMPLETAS

### NIS2 (Directiva 2022/2555 UE)

- Artículo 15: Designación responsable
- Artículo 18: Roles especializados
- Artículo 19: Notificación de incidentes
- Artículo 20: Medidas técnicas y organizacionales (21 medidas)
- Artículo 21: Criterios auditoría / Notificación  $< 24$ h

### ISO/IEC 27001:2022

- 6.1: Determinar alcance
- 7.3: Conciencia
- 8.1-8.37: 37 Controles de seguridad
- 9.1-9.3: Evaluación conformidad
- 10: Mejora continua

## NIST Cybersecurity Framework v2.0

- Govern: Estrategia, objetivos, políticas
- Identify: Activos, amenazas, vulnerabilidades
- Protect: Controles, defensa
- Detect: Monitoreo, detección
- Respond: Plan, respuesta, recuperación
- Recover: Continuidad, resiliencia

## Fin de Mapeo Normativo

*Versión 2.0 | Enero 2026*